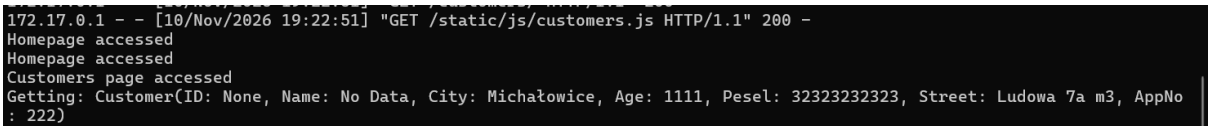
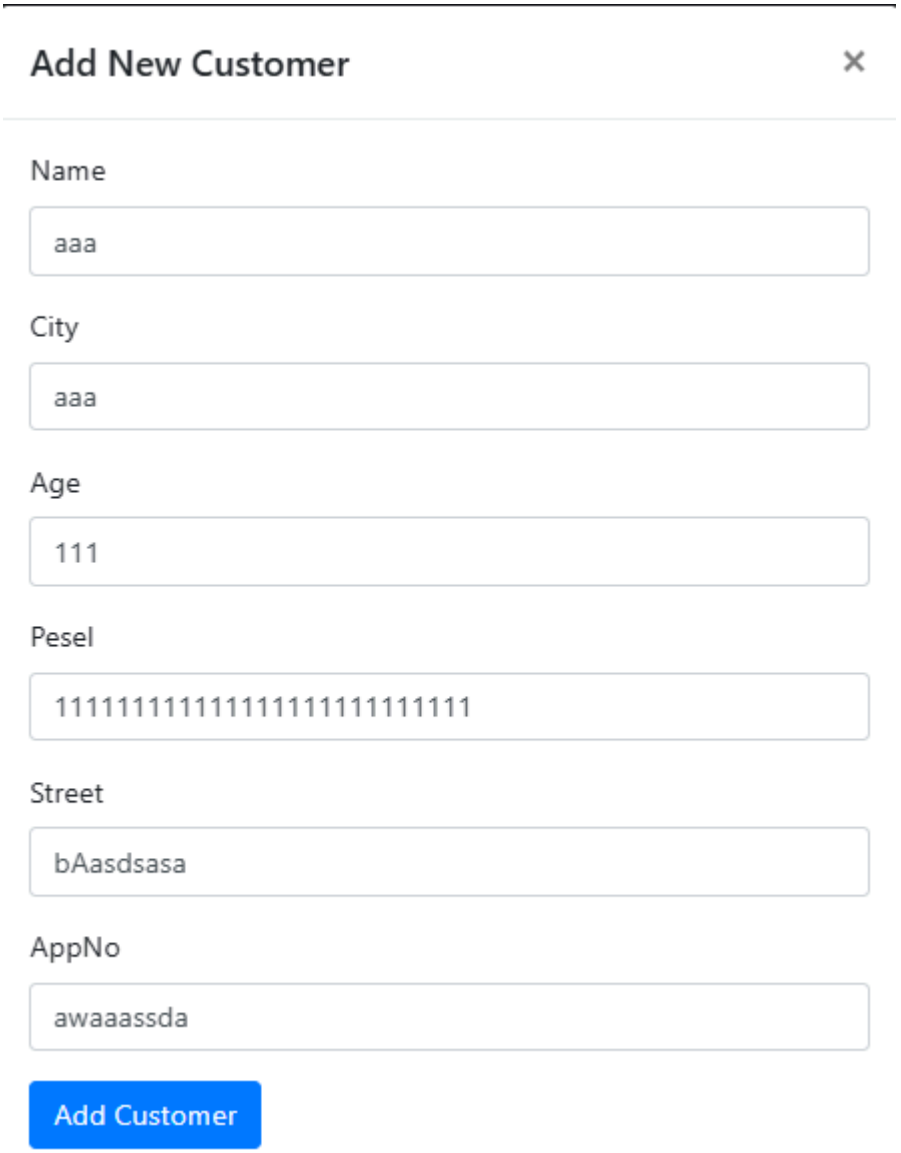
Zadanie 1

Dane wprowadzone przy tworzeniu nowego customera są wyświetlane bezpośrednio w logach, razem z PESELem i adresem, jak widać poniżej.



Po zmodyfikowaniu przeze mnie logów (dodaniu funkcji maskującej), dane nie są wyświetlane bezpośrednio.



Zdecydowałem się zamaskować PESEL i numer ulicy. Bez nich osoba powinna nie być identyfikowalna. Dodanie takiego maskowania jest trywialne, co widać w kodzie, więc w wypadku uznania że inne dane w tym logu są poufne można je prosto zamaskować.

```
172.17.0.1 - - [10/Nov/2026 19:34:31] "GET /customers/ HTTP/1.1" 200 -
172.17.0.1 - - [10/Nov/2026 19:34:31] "GET /static/js/customers.js HTTP/1.1" 304 -
Customers page accessed
Getting: Customer(ID: None, Name: aaa, City: aaa, Age: 111, Pesel: **************************, Street: *********, AppNo
: awaaassda)
```

Zadanie 2

Po wywołaniu skanera wykryty 3 commity z danymi poufnymi:





Odpowiednio podlinkowane:

1. https://github.com/franciszekfabisiak/task2/blob/de9d7b8cb63bd7ae741ec5c9e23891b71709bc28/deployment2.key#L1
2. https://github.com/franciszekfabisiak/task2/blob/bc17b7ddc46f46fff175aed55d68e11bb48166cc/deployment.key
3. https://github.com/franciszekfabisiak/task2/blob/bc17b7ddc46f46fff175aed55d68e11bb48166cc/awscredentials.json#L5

W każdym z tych 3 linków wyraźnie widać klucz prywatny - skaner wykrył prawdziwe naruszenia bezpieczeństwa.

Zadanie 3

Skaner wykrył wiele podatności, z których wybrałem moim zdanime najbardziej krytyczną. Jest to podatność Jinja2 Sandbox Bypasses (IDs 75976, 76378, 74735) Risk Level: Critical (Remote Code Execution).

Wykorzystanie tej podatności jest możliwe wyłącznie przy użyciu klasy SandboxedEnvironment z modułu jinja2.sandbox oraz przy istnieniu wektora pozwalającego użytkownikowi na zdefiniowanie własnej struktury szablonu (SSTI).

Po analizie kodu badanej aplikacji ustalono, że klasa SandboxedEnvironment nie jest w ogóle importowana ani wykorzystywana, a szablony renderowane są wyłącznie ze statycznych plików szablonów przy użyciu standardowej funkcji render_template(). W związku z tym podatne ścieżki wykonania są nieosiągalne, a rzeczywiste prawdopodobieństwo i możliwość wykorzystania tej podatności w badanej aplikacji jest minimalne.